

Cybersecurity Daily Newsletter

Vol. 001 | 2026-05-18 07:00 WIB

Top 5 Highlights

- New Windows 'MiniPlasma' zero-day exploit gives SYSTEM access, PoC released
- [+24h Old] PoC code published for critical NGINX vulnerability (CVE-2026-42945)
- Grafana Labs security breach: attackers accessed GitHub token and downloaded private codebase
- [+24h Old] Shai-Hulud worm steals npm, GitHub, AWS, and Kubernetes secrets from developers
- [+24h Old] Google Project Zero discloses zero-click exploit chain for Pixel 10 devices

Threat Intelligence (10)

01. Tycoon2FA hijacks Microsoft 365 accounts via device-code phishing

Threat researchers reported Tycoon2FA operators abusing Microsoft OAuth device-code flows to obtain tokens and hijack Microsoft 365 accounts.

Why it matters: Token-based takeover can bypass traditional password theft patterns and enable BEC, data theft, and persistence in cloud identities.

Recommendation: Limit/disable device-code flow where feasible, enforce Conditional Access, and monitor Entra ID sign-ins for deviceCode patterns and anomalous token issuance.

Sources: <https://www.bleepingcomputer.com/news/security/tycoon2fa-hijacks-microsoft-365-accounts-via-device-code-phishing/>

02. [+24h Old] Russian hackers turn Kazuar backdoor into modular P2P botnet

A Russia-linked actor reportedly evolved the Kazuar backdoor into a modular peer-to-peer botnet to improve stealth, resilience, and long-term access.

Why it matters: P2P architectures can make detection and disruption harder, supporting extended espionage and follow-on intrusion activity.

Recommendation: Hunt for Kazuar indicators, baseline DNS and unusual peer-to-peer traffic, and rotate credentials/tokens when compromise is suspected.

Sources: <https://www.bleepingcomputer.com/news/security/russian-hackers-turn-kazuar-backdoor-into-modular-p2p-botnet/>

03. [+24h Old] Popular node-ipc npm package compromised to steal credentials

Malicious node-ipc versions were published to steal cloud and developer secrets and exfiltrate them via DNS TXT queries in a supply-chain attack.

Why it matters: Compromised dependencies can leak CI/CD and cloud credentials, enabling rapid escalation from developer machines to production environments.

Recommendation: Remove affected versions, audit lockfiles and caches, rotate exposed secrets, and enforce dependency integrity controls and monitoring in build pipelines.

Sources: <https://www.bleepingcomputer.com/news/security/popular-node-ipc-npm-package-compromised-to-steal-credentials/>

04. [+24h Old] Shai-Hulud worm steals npm, GitHub, AWS, and Kubernetes secrets from developers

Reports described Shai-Hulud-style activity focused on harvesting developer tokens and cloud/Kubernetes secrets through supply-chain and credential-stealing tradecraft.

Why it matters: Developer credential theft is a high-leverage path to compromise source code, pipelines, and cloud resources.

Recommendation: Enforce least-privilege tokens, rotate developer credentials, implement secret scanning, and monitor for unusual package behavior and token use.

Sources: <https://cybersecuritynews.com/shai-hulud-worm-steals-npm/>

05. [+24h Old] Gunra ransomware expands RaaS operations after shifting from Conti-based locker

Threat reporting indicated the Gunra ransomware operation expanded its RaaS activity and updated tooling after earlier locker lineage.

Why it matters: RaaS ecosystem churn drives new intrusion waves and increases the likelihood of opportunistic targeting.

Recommendation: Harden internet-facing services, validate backup and recovery, and monitor for common initial-access indicators tied to ransomware affiliate activity.

Sources: <https://cybersecuritynews.com/gunra-ransomware-expands-raas-operations/>

06. [+24h Old] Hackers abuse OAuth device authorization flow to steal Microsoft 365 tokens

Attackers were reported abusing OAuth device authorization flows to trick users into authorizing attacker-controlled sessions and issuing Microsoft 365 tokens.

Why it matters: Device-code phishing is difficult to stop with password policies alone and can undermine MFA when token issuance is abused.

Recommendation: Review OAuth device-code settings, tighten Conditional Access policies, and alert on suspicious device-code sign-ins and token grants.

Sources: <https://cybersecuritynews.com/hackers-abuse-oauth-device-authorization-flow/>

07. [+24h Old] OpenAI confirms limited internal impact from TanStack npm supply chain attack

OpenAI reported limited internal device impact linked to the TanStack npm supply-chain incident, with no reported effect on production systems or user data.

Why it matters: Supply-chain compromises can reach developer endpoints and propagate into builds if not contained quickly.

Recommendation: Pin dependencies, verify package integrity, monitor developer endpoints, and ensure rapid isolation and credential rotation after supply-chain alerts.

Sources: <https://openai.com/index/our-response-to-the-tanstack-npm-supply-chain-attack/>

08. [+24h Old] JDownloader website compromised to distribute malicious Windows and Linux installers

Reports alleged the JDownloader distribution channel was abused to deliver malicious installers for multiple platforms.

Why it matters: Trojanized installers provide a scalable delivery mechanism for credential theft, botnets, and ransomware.

Recommendation: Validate software signatures and hashes, restrict execution of untrusted binaries, and monitor endpoints for suspicious installer behavior.

Sources: <https://cybersecuritynews.com/jdownloader-website-compromised/>

09. [+24h Old] Pwn2Own Berlin 2026 Day 2 highlights: Exchange, Windows 11, Linux, and AI tools exploited

Day-two Pwn2Own reporting highlighted multiple high-impact exploit chains demonstrated against major platforms and tooling.

Why it matters: Contest exploits often foreshadow real-world weaponization once patches land and technical details circulate.

Recommendation: Track vendor advisories, prioritize patching for exposed systems, and ensure compensating controls are in place for vulnerable services.

Sources: <https://cybersecuritynews.com/microsoft-exchange-windows-11-and-cursor-zero-days-exploited-pwn2own/>

10. [+24h Old] Funnel Builder WordPress plugin bug actively exploited to steal credit cards

A WordPress Funnel Builder plugin vulnerability was reported under active exploitation to inject skimmers and steal credit card data at checkout.

Why it matters: Checkout skimming produces direct financial loss and reputational damage, especially for widely deployed e-commerce plugins.

Recommendation: Patch immediately, scan for injected JavaScript/webshells, monitor payment pages for tampering, and rotate exposed credentials.

Sources: <https://www.bleepingcomputer.com/news/security/funnel-builder-wordpress-plugin-bug-exploited-to-steal-credit-cards/>

Latest Vulnerabilities (10)

01. New Windows 'MiniPlasma' zero-day exploit gives SYSTEM access, PoC released

A Windows local privilege escalation zero-day dubbed 'MiniPlasma' was reported with proof-of-concept code allegedly enabling SYSTEM-level access.

Why it matters: Public PoCs for LPE flaws can rapidly increase exploitation attempts, especially when combined with common initial-access vectors.

Recommendation: Prioritize patching once available, enforce least privilege, and monitor endpoints for suspicious token manipulation and privilege escalation behavior.

Sources: <https://www.bleepingcomputer.com/news/microsoft/new-windows-miniplasma-zero-day-exploit-gives-system-access-poc-released/>

02. [+24h Old] Microsoft rejects critical Azure Backup for AKS vulnerability report, no CVE issued

A researcher alleged Microsoft addressed an Azure Backup for AKS issue without issuing a CVE, while Microsoft disputed the characterization.

Why it matters: Cloud security misunderstandings can leave tenants exposed when assumptions about default protections differ from actual behavior.

Recommendation: Review Azure Backup for AKS configurations and permissions, validate logging/auditing, and apply defense-in-depth controls for backup and restore operations.

Sources: <https://www.bleepingcomputer.com/news/security/microsoft-rejects-critical-azure-vulnerability-report-no-cve-issued/>

03. [+24h Old] PoC code published for critical NGINX vulnerability (CVE-2026-42945)

Proof-of-concept exploit code was published for a critical NGINX vulnerability tracked as CVE-2026-42945.

Why it matters: Public PoCs for widely deployed web infrastructure can quickly drive scanning and exploitation attempts.

Recommendation: Patch or apply mitigations immediately, limit exposure of NGINX instances, and monitor web logs/WAF telemetry for exploit attempts.

Sources: <https://www.securityweek.com/poc-code-published-for-critical-nginx-vulnerability/>

04. [+24h Old] Android 16 VPN bypass (Tiny UDP Cannon) lets apps reveal real IP address

Reporting described an Android 16 VPN bypass technique that could allow apps to leak a device's real IP address under certain conditions.

Why it matters: VPN bypass techniques undermine privacy controls and may expose users to tracking, targeting, or policy violations.

Recommendation: Monitor vendor guidance, update devices promptly, and validate VPN enforcement for high-risk users and managed fleets.

Sources: <https://cybersecuritynews.com/android-16-vpn-bypass/>

05. [+24h Old] Google Project Zero discloses zero-click exploit chain for Pixel 10 devices

Project Zero reportedly disclosed a zero-click exploit chain affecting Pixel 10 devices, highlighting risks in mobile attack surfaces.

Why it matters: Zero-click chains can enable compromise without user interaction, often impacting high-value targets.

Recommendation: Apply patches quickly, reduce attack surface (messaging apps/services), and ensure mobile EDR/MDM policies are enforced.

Sources: <https://cybersecuritynews.com/zero-click-exploit-chain-pixel-10-devices/>

06. [+24h Old] Malicious JPEG images could trigger PHP memory safety vulnerabilities

Security reporting warned that crafted JPEG images could trigger memory safety bugs in certain PHP image-processing contexts.

Why it matters: Image parsing vulnerabilities can be exploited via user-upload or content ingestion paths, potentially leading to crashes or code execution.

Recommendation: Update PHP and image libraries, sandbox image processing, and restrict untrusted upload paths.

Sources: <https://cybersecuritynews.com/malicious-jpeg-images-php-memory-safety-vulnerabilities/>

07. [+24h Old] Linux kernel flaw CVE-2026-46333 (ssh-keysign-pwn) exposes SSH keys and shadow passwords

A Linux kernel-related vulnerability (CVE-2026-46333) was reported with potential exposure of SSH keys and sensitive credential material in some scenarios.

Why it matters: Credential exposure on Linux hosts can enable lateral movement and persistent access in enterprise environments.

Recommendation: Patch affected kernels, audit SSH key material handling, and monitor for unusual access to key and shadow files.

Sources: <https://cybersecuritynews.com/linux-kernel-vulnerability-ssh-keysign-pwn/>

08. [+24h Old] Claw Chain vulnerabilities put OpenClaw AI agent servers at risk (CVE-2026-44112/44113/44115/44118)

Multiple CVEs were reported impacting OpenClaw AI agent server deployments, potentially exposing sensitive data or enabling compromise.

Why it matters: AI agent services frequently handle credentials and privileged actions; vulnerabilities can have outsized downstream impact.

Recommendation: Patch promptly, restrict network exposure, and enforce authentication/authorization for agent endpoints.

Sources: <https://hackread.com/claw-chain-vulnerabilities-openclaw-ai-servers-risk/>

09. [+24h Old] Avada Builder WordPress plugin flaws allow file read and SQL injection (CVE-2026-4782, CVE-2026-4798)

Two vulnerabilities in Avada Builder could allow arbitrary file reads and SQL injection conditions leading to sensitive data exposure and potential site takeover.

Why it matters: High-install-base WordPress plugin flaws can be rapidly weaponized for mass exploitation.

Recommendation: Update Avada Builder to a fully patched version and review logs for suspicious requests and unauthorized access.

Sources: <https://www.bleepingcomputer.com/news/security/avada-builder-wordpress-plugin-flaws-allow-site-credential-theft/>

10. [+24h Old] Windows BitLocker zero-days: YellowKey encryption bypass and GreenPlasma privilege escalation

Reporting described BitLocker-related zero-day issues including an encryption bypass (YellowKey) and a privilege escalation (GreenPlasma) in certain conditions.

Why it matters: Disk encryption bypass and privilege escalation issues can undermine endpoint security assumptions and incident containment.

Recommendation: Apply vendor updates as available, validate BitLocker configuration baselines, and restrict local admin privileges.

Sources: <https://cybersecuritynews.com/windows-bitlocker-0-day-vulnerability/>

Data Breach & Cybercrime (10)

01. Grafana Labs security breach: attackers accessed GitHub token and downloaded private codebase

Grafana Labs reportedly disclosed a breach involving access to a GitHub token and download of a private code repository.

Why it matters: Source-code access can enable supply-chain attacks, vulnerability discovery, and exposure of embedded secrets.

Recommendation: Rotate compromised tokens/secrets, review access logs, and strengthen repository protections (least privilege, MFA, and secret scanning).

Sources: <https://cybersecuritynews.com/grafana-labs-security-breach/>

02. [+24h Old] Trellix source code breach claimed by RansomHouse hackers

RansomHouse claimed a breach of Trellix involving alleged source-code exposure, consistent with extortion-driven disclosure tactics.

Why it matters: Extortion groups use source-code theft to pressure victims and potentially enable follow-on targeting.

Recommendation: Validate exposure scope, rotate secrets, monitor for leaked artifacts, and prepare customer communications and legal/regulatory response.

Sources: <https://www.bleepingcomputer.com/news/security/trellix-source-code-breach-claimed-by-ransomhouse-hackers/>

03. [+24h Old] Canvas/Instructure incident: disruption and data exposure amid ShinyHunters extortion claims

Reporting covered disruption and alleged data exposure related to the Canvas/Instructure incident and extortion claims.

Why it matters: Education platforms hold large volumes of PII and are frequent targets for extortion and data-theft campaigns.

Recommendation: Review incident response communications, enforce strong authentication, and monitor for abnormal data access or exfiltration.

Sources: <https://www.securityweek.com/deal-reached-with-hackers-to-delete-data-stolen-from-the-canvas-educational-platform/>

04. [+24h Old] American Lending Center data breach affects 123,000 individuals after ransomware incident

American Lending Center disclosed a ransomware incident impacting roughly 123,000 individuals, following investigation into accessed data.

Why it matters: Financial-sector breaches can increase identity fraud risk and enable targeted phishing and account takeover.

Recommendation: Strengthen backup/IR readiness, rotate credentials, and implement enhanced fraud monitoring and customer notifications as needed.

Sources:

<https://www.securityweek.com/american-lending-center-data-breach-affects-123000-individuals/>

05. [+24h Old] Foxconn confirms North American factories hit by cyberattack claimed by Nitrogen ransomware group

Foxconn confirmed a cyberattack impacting North American operations, reportedly linked to a ransomware group claiming responsibility.

Why it matters: Manufacturing disruptions can cause supply-chain impacts and may lead to data exposure and extended downtime.

Recommendation: Segment OT/IT networks, validate incident containment, and ensure backups and restoration processes are tested.

Sources: <https://www.securityweek.com/foxconn-confirms-north-american-factories-hit-by-cyberattack/>

06. [+24h Old] 716,000 impacted by OpenLoop Health data breach

OpenLoop Health reported a data breach impacting hundreds of thousands of individuals, according to disclosure reporting.

Why it matters: Healthcare data breaches can enable identity theft and targeted scams due to sensitivity of medical and personal information.

Recommendation: Enforce MFA, limit third-party access, monitor for misuse of exposed data, and implement enhanced patient notification and support processes.

Sources: <https://www.securityweek.com/716000-impacted-by-openloop-health-data-breach/>

07. [+24h Old] Skoda discloses data breach affecting online shop customers

Skoda reported a breach affecting customers of its online shop, with disclosure describing impacted data categories.

Why it matters: Retail breaches can lead to credential stuffing, payment fraud, and phishing against affected customers.

Recommendation: Reset/rotate exposed credentials, enforce MFA, and monitor for account takeover and payment fraud patterns.

Sources: <https://www.securityweek.com/skoda-data-breach-hits-online-shop-customers/>

08. [+24h Old] Vimeo data breach exposes personal information of 119,000 people

Vimeo disclosed a data breach affecting roughly 119,000 individuals, according to reporting.

Why it matters: Large-scale PII exposure increases risk of phishing, account takeover, and identity fraud.

Recommendation: Notify affected users, force password resets where needed, and implement monitoring for suspicious login patterns.

Sources: <https://www.bleepingcomputer.com/news/security/vimeo-data-breach-exposes-personal-information-of-119-000-people/>

09. [+24h Old] West Pharmaceutical Services hit by disruptive ransomware attack

West Pharmaceutical Services reported a disruptive ransomware incident impacting operations.

Why it matters: Ransomware disruption in critical manufacturing can impact supply chains and patient safety indirectly.

Recommendation: Improve segmentation, test backups, and implement rapid isolation procedures; monitor for data theft indicators and extortion activity.

Sources:

<https://www.securityweek.com/west-pharmaceutical-services-hit-by-disruptive-ransomware-attack/>

10. [+24h Old] Sandhills Medical says ransomware breach affects 170,000

Sandhills Medical reported a ransomware-related breach affecting approximately 170,000 individuals.

Why it matters: Healthcare ransomware incidents can combine downtime with sensitive data exposure, increasing harm to patients and operations.

Recommendation: Enhance detection for ransomware precursors, validate recovery processes, and strengthen access controls and monitoring around PHI systems.

Sources: <https://www.securityweek.com/sandhills-medical-says-ransomware-breach-affects-170000/>